Aligning cybersecurity investment with business-impact risk: A knowledge-based AI decision-support model evaluated on real-world incident data

Short Communication

Rahul Chandra Nandagiri[a,*]

[a] *Doctor of Business Administration Program, Midwest University, Wentzville, Missouri, United States*

[*] Corresponding author. E-mail address: chandrarahul416@gmail.com

Abstract

Cybersecurity budgets are often allocated by threat frequency or spread evenly across controls, although business performance is damaged mainly by the minority of incidents that disrupt operations or expose data at scale. This Short Communication presents KB-CIDS (Knowledge-Based Cybersecurity Investment Decision Support), a model that aligns cybersecurity investment with business-impact risk. KB-CIDS couples a 22-rule knowledge base that maps incident patterns to nine control families aligned with CIS Controls v8 and the NIST Cybersecurity Framework 2.0, a calibrated gradient-boosting model of material business impact that uses knowledge features, and a Gordon–Loeb budget optimizer with context and recency weighting. Using 9,284 public incidents from the VERIS Community Database, all components were developed on incidents up to 2016 and evaluated out of time on 2017–2026. The materiality model reached a ROC-AUC of 0.891 (95% CI 0.873–0.911), above gradient boosting without knowledge features (0.883) and expert rules (0.833). Across 18 sector–size profiles, threat-frequency allocation achieved a lower business-impact risk reduction (BIRR) than an equal split (0.483 vs 0.500), whereas KB-CIDS reached 0.588, outperformed both in all 18 profiles (Wilcoxon $p < 0.001$) and closed 56% of the gap to an ex-post oracle. Ablations show that impact alignment and recency weighting drive the gain, whereas machine-learning imputation of incidents with unknown impact did not improve out-of-time allocation (BIRR 0.599 without it). The results held across alternative impact thresholds, split years and investment-response parameters. Knowledge-based impact alignment, rather than threat counts, should therefore guide cybersecurity investment in digitally transforming organizations.

Keywords: Knowledge-based decision support; Cybersecurity investment; Business impact; Incident data; Digital transformation

1. Introduction

Digital transformation embeds information systems in how organizations create and capture value [1,2]. As a consequence, cyber incidents that interrupt operations or expose data at scale translate directly into business-performance losses: successful attacks reduce shareholder wealth and sales growth and impose reputational losses that exceed out-of-pocket costs [3], they move stock-market activity [4], and they depress the market value of breached listed companies [5]. Cyber losses are also heavy-tailed, so a minority of events accounts for most of the damage [6]. Conversely, institutionalized security capability is associated with higher profitability and labor productivity [7] and with better organizational performance [8], and investors reassess their interest in a firm after a breach [9]. For managers the question is therefore not whether to invest in cybersecurity, but where the next unit of budget removes the most business-impact risk.

Economic models address this question analytically. The Gordon–Loeb model relates investment to vulnerability, expected loss and investment productivity [10]; extensions allocate budgets across concurrent heterogeneous attacks [11], competing or cooperating firms [12] and supply chains [13], and add social-welfare [14], real-options [15] and net-present-value [16] perspectives, while decision-support tools combine game theory with combinatorial optimization [17]. These models, however, assume that loss and vulnerability parameters are known. In practice, investment tends to follow past attacks and existing capabilities [18], and organizations rarely verify ex post whether the expected benefits were realized [19]. Data-driven research, in turn, models hacking-breach risk [20,21], documents shifting breach patterns in sectors such as healthcare [22,23], and applies machine learning to detection [24,25], with growing attention to explainability [26,27] and knowledge graphs [28–30]. The two streams rarely meet. Predictive models are seldom connected to codified control knowledge and budget optimization, and allocation models are seldom validated out of time on real incident data, where the dataset shift between past and future threat mixes [31]—for example, the rise of ransomware [32]—is severe.

This Short Communication addresses that gap with KB-CIDS (Knowledge-Based Cybersecurity Investment Decision Support). KB-CIDS couples (i) a production-rule knowledge

base that translates incident patterns into nine control families aligned with the CIS Critical Security Controls v8 [33] and the NIST Cybersecurity Framework 2.0 [34]; (ii) a calibrated AI model of material business impact that uses knowledge features; and (iii) a Gordon–Loeb allocation layer with context and recency weighting. The contribution is threefold: a transparent knowledge-based formulation that links incident data, control knowledge and investment response; an out-of-time evaluation on 9,284 public incidents [35] that tests whether business-impact alignment outperforms threat-frequency and undifferentiated budgeting; and a component ablation, reported together with its negative result, supported by a reproducible open-source implementation.

2. The KB-CIDS model

2.1. Problem formulation

Let i index historical incidents, each described by firm context (sector σ_i, size band ζ_i and region), a threat pattern (VERIS action varieties and vectors, actors and assets), an incident year t_i and an outcome. An incident has material business impact (MBI) when it disrupts operations or exposes data at scale, as defined in Eq. (1):

$$y_i = \mathbb{1}\left[A_i \cap \mathscr{D} \neq \varnothing \vee R_i \geq \tau\right] \tag{1}$$

where A_i is the set of availability effects, $\mathscr{D}$ = {interruption, obscuration, destruction, degradation}, R_i is the number of compromised records and τ = 10,000. The outcome is undetermined when no disruption is recorded and R_i is unknown. For a firm profile p and a budget B allocated across $K = 9$ control families, the residual risk addressed by family c after investment z_c follows the Gordon–Loeb class-I breach-probability function [10], Eq. (2), and the investment decision is the program in Eq. (3):

$$S(z_c) = (\alpha z_c + 1)^{-\beta}, \alpha > 0, \beta \geq 1 \tag{2}$$

$$\min_z \sum_{c=1}^{K} s_c(p) S(z_c) \quad \text{subject to} \quad \sum_{c=1}^{K} z_c = B, z_c \geq 0 \tag{3}$$

4

where $s_c(p)$ is the share of the profile's business-impact risk that family c addresses (Section 2.3). The Karush–Kuhn–Tucker conditions give the water-filling solution in Eq. (4), in which the multiplier λ is found by bisection so that the allocations sum to B:

$$z_c^{\dot{c}} = max\left\{0, \frac{\left(\frac{\alpha\beta\, s_c(p)}{\lambda}\right)^{1/(\beta+1)} - 1}{\alpha}\right\} \quad (4)$$

Families that address a larger share of business-impact risk receive more budget, with diminishing returns, which preserves the Gordon–Loeb insight that more spending is not always better [10,11].

2.2. Knowledge base and AI materiality model

The knowledge base contains 22 production rules (R1–R22; Table S1) that map VERIS patterns to nine families: F1 identity and access management, F2 vulnerability and secure configuration, F3 email/web protection and awareness, F4 malware defense and threat detection, F5 backup, recovery and resilience, F6 data protection and handling, F7 insider and privileged-activity monitoring, F8 physical and asset security, and F9 third-party and supply-chain risk. For example, use of stolen credentials triggers F1 (R1), exploitation of vulnerabilities or SQL injection triggers F2 (R2), ransomware triggers F4 and F5 (R9–R10), misdelivery and publishing errors trigger F6 (R18), and partner involvement triggers F9 (R22). The rule hits of incident i are normalized into a vector $\mathbf{K}_i$ with $\Sigma_c K_{ic} = 1$; the rules cover 97.4% of incidents. Three consequence rules flag patterns prone to disruption (C1), mass data exposure (C2) or contained impact (C3).

The AI materiality model is a histogram gradient-boosting classifier that estimates $\hat{p}_i = P(y_i = 1)$ from 176 pre-incident features: 164 indicators of context and threat pattern, whose vocabulary is learned on the development period only, plus 12 knowledge features ($\mathbf{K}_i$ and the consequence flags). Outcome fields are never used as inputs. Isotonic calibration with five-fold cross-fitting converts scores into probabilities. The model supports prospective scoring of threat scenarios and imputes the impact weight $\pi_i = \hat{p}_i$ of incidents whose outcome is undetermined ($\pi_i = y_i$ otherwise).

5

2.3. Context- and recency-weighted risk shares

Historical incidents are weighted for a target profile $p = (\sigma_p, \zeta_p)$ at reference year T by Eq. (5), where λ_s shares evidence across size bands, λ_g borrows strength from other sectors, and the half-life h discounts older evidence. The recency term operationalizes a governance-and-learning loop that re-estimates priorities as threats evolve. The business-impact risk shares then follow Eq. (6), and Algorithm 1 summarizes the procedure.

$$w_i(p) = \left[\mathbb{1}(\sigma_i = \sigma_p)\left(\mathbb{1}(\zeta_i = \zeta_p) + \lambda_s \mathbb{1}(\zeta_i \neq \zeta_p)\right) + \lambda_g\right] \cdot 2^{-(T - t_i)/h} \tag{5}$$

$$s_c(p) = \frac{\sum_i w_i(p)\,\pi_i K_{ic}}{\sum_{c'} \sum_i w_i(p)\,\pi_i K_{ic'}} \tag{6}$$

Algorithm 1. KB-CIDS investment decision support

Input: incident history; target profile p; budget B; parameters (α, β, λ_s, λ_g, h)
Output: allocation $\mathbf{z}^*(p)$ with a rule-level explanation
1: Apply rules R1–R22 and C1–C3 to every incident to obtain $\mathbf{K}_i$ and the consequence flags.
2: Fit the calibrated materiality model on incidents with determined outcomes; set $\pi_i = y_i$ or $\hat{p}_i$.
3: Compute the weights $w_i(p)$ (Eq. 5) and the risk shares $s_c(p)$ (Eq. 6).
4: Solve the budget allocation (Eq. 4) by bisection on λ.
5: For each family, report the threat patterns that contribute most of its risk share.
6: Repeat steps 2–5 when new outcome data arrive, re-selecting (λ_s, λ_g, h) on the latest validation window.

3. Experimental design

Data. The VERIS Community Database (VCDB) codes publicly reported incidents in the Vocabulary for Event Recording and Incident Sharing [35]. The joined release at commit f6f98c0 (30 September 2026; CC BY-SA 4.0) contains 10,047 incidents. Confirmed or suspected incidents dated 2000–2026 were retained, and 747 bulk-encoded MOVEit records from 2023, which share a single summary and would otherwise dominate the later period, were excluded. This left 9,284 incidents across 13 named sectors plus an other/unknown group; outcomes were determined for 6,074 of them.

Protocol. The development period comprises incidents up to 2016 (n = 7,438; 4,941 determined; MBI prevalence 26.7%) and the out-of-time evaluation period covers 2017–2026 (n =

1,846; 1,133 determined; prevalence 62.9%). For every strategy, the weighting parameters ($\lambda_s \in \{0.25, 0.5, 1\}$; $\lambda_g \in \{0, 0.01, 0.02, 0.05, 0.1, 0.2, 0.5, 1\}$; $h \in \{0.5, 1, 2, 4, 8, \infty\}$ years) were selected on an inner split (training up to 2014, validation 2015–2016) and frozen before evaluation.

Baselines. The predictive baselines are a historical lookup of MBI rates by action category, the expert consequence rules with Platt scaling, logistic regression (C selected by five-fold cross-validation), a random forest (500 trees) and gradient boosting without knowledge features, all implemented in scikit-learn [36]. The decision baselines are equal allocation (undifferentiated spending), threat-frequency allocation in which every historical incident counts equally (pooled or context-weighted), impact-aligned allocation pooled across organizations, three ablations of KB-CIDS (without context weighting, without recency weighting and without AI imputation) and an ex-post oracle that knows the realized risk shares of the evaluation period.

Metrics. Prediction is assessed with ROC-AUC, PR-AUC, the Brier score and the expected calibration error (ECE, ten bins), using 2,000 bootstrap resamples and paired bootstrap tests. For a profile p, the realized shares $s_c^E(p)$ are computed from its observed MBI incidents in the evaluation period, and the business-impact risk reduction (BIRR) of an allocation is given by Eq. (7):

$$BIRR(p) = 1 - \sum_{c=1}^{K} s_c^E(p)\, S\left(z_c^{\iota}(p)\right) \tag{7}$$

The share of the oracle gap closed, $(\mathrm{BIRR} - \mathrm{BIRR}_{\mathrm{equal}})/(\mathrm{BIRR}_{\mathrm{oracle}} - \mathrm{BIRR}_{\mathrm{equal}})$, expresses performance relative to the best achievable allocation. Profiles are sector–size cells with at least ten mapped MBI incidents in the evaluation period (18 profiles with 11–90 incidents each). The reference budget is $B = 9$ (one unit per family) with $\alpha = \beta = 1$, so that equal allocation removes exactly half of the risk. Strategies are compared across profiles with two-sided Wilcoxon signed-rank tests, and 95% confidence intervals resample evaluation incidents within profiles (1,000 draws). Robustness checks raise the record threshold to $\tau = 100{,}000$, exclude non-randomly sampled VCDB sub-sources, move the split year to 2015 or 2017, admit profiles with at least five

incidents, vary $\alpha \in \{0.5, 1, 2\}$ and $\beta \in \{1, 2, 3\}$, and scale the budget from 0.1 to 10 times the reference.

4. Results and discussion

4.1. Predicting material business impact

Table 1 reports the out-of-time prediction results. The KB-CIDS materiality model achieved the highest discrimination (ROC-AUC 0.891; PR-AUC 0.932), ahead of gradient boosting without knowledge features (0.883; ΔAUC = 0.009, $p = 0.001$), the random forest (0.865), logistic regression (0.849), the expert rules (0.833) and the historical lookup (0.679; all $p < 0.001$). Knowledge features were among the most influential inputs: the resilience-family weight produced the largest permutation loss (ΔAUC = 0.074) and the contained-impact rule ranked fifth (Table S7). Calibration deteriorated out of time for every model (ECE 0.118–0.270) because MBI prevalence rose from 26.7% to 62.9% as exploitation and ransomware gained weight; this drift is the reason the decision layer discounts older evidence.

Table 1. Out-of-time prediction of material business impact (development ≤2016; evaluation 2017–2026; n = 1,133 incidents with determined outcomes, 62.9% material).

Model	ROC-AUC (95% CI)	PR-AUC	Brier	ECE	ΔAUC (p)
Historical lookup (action category)	0.679 (0.647–0.710)	0.759	0.288	0.270	-0.212 (<0.001)
Expert consequence rules (Platt-calibrated)	0.833 (0.810–0.856)	0.861	0.194	0.188	-0.058 (<0.001)
Logistic regression	0.849 (0.827–0.871)	0.906	0.189	0.181	-0.042 (<0.001)
Random forest	0.865 (0.844–0.887)	0.915	0.176	0.180	-0.026 (<0.001)
Gradient boosting (no knowledge features)	0.883 (0.864–0.902)	0.928	0.150	0.118	-0.009 (0.001)
KB-CIDS materiality model	**0.891 (0.873–0.911)**	**0.932**	**0.151**	**0.130**	**—**

ROC-AUC confidence intervals from 2,000 bootstrap resamples; ΔAUC and p from paired bootstrap tests against the KB-CIDS model. Lower Brier and ECE values are better. Confidence intervals for all metrics are given in Table S10.

4.2. Investment decisions

Table 2 and Figs. 1–2 summarize the decision results. Allocating by threat frequency removed less business-impact risk than an equal split (BIRR 0.483 with context weighting and 0.443 pooled, vs 0.500), because the most frequent incidents—handling errors, insider misuse and physical theft

8

—are rarely material. On average, threat-frequency allocation placed 59.0% of the budget in F6–F8, whereas these families held only 10.3% of the realized material-impact risk (Fig. 1). Pooled impact-aligned allocation already improved on the equal split (0.553; better in 15 of 18 profiles). KB-CIDS reached 0.588 (95% CI 0.577–0.599), outperformed both equal and threat-frequency allocation in all 18 profiles ($p < 0.001$; per-profile gains over threat-frequency allocation of 0.022–0.175) and closed 56.5% of the gap to the oracle (0.656). It shifted budget toward vulnerability management, malware defense and resilience (F2, F4 and F5 received 52.2% of the budget vs 28.6% under threat-frequency allocation), where 71.6% of the realized risk occurred.

Table 2. Out-of-time investment-decision performance at the reference budget (18 sector–size profiles, 2017–2026).

Strategy	Mean BIRR (95% CI)	Δ vs equal (pp)	Oracle gap closed (%)	Profiles > equal	p vs KB-CIDS
Equal allocation (undifferentiated)	0.500	+0.0	0.0	0/18	<0.001
Threat frequency, pooled	0.443 (0.424–0.461)	-5.7	-36.4	6/18	<0.001
Threat frequency, context-weighted	0.483 (0.468–0.498)	-1.7	-10.6	8/18	<0.001
Impact-aligned, pooled	0.553 (0.537–0.566)	+5.3	33.7	15/18	<0.001
KB-CIDS without context weighting	0.585 (0.574–0.596)	+8.5	54.7	18/18	0.074
KB-CIDS without recency weighting	0.567 (0.556–0.577)	+6.7	42.7	16/18	<0.001
KB-CIDS without AI imputation	0.599 (0.586–0.610)	+9.9	63.4	18/18	<0.001
KB-CIDS (full model)	**0.588 (0.577–0.599)**	**+8.8**	**56.5**	**18/18**	**—**
Oracle (ex post upper bound)	0.656 (0.642–0.669)	+15.6	100.0	18/18	<0.001

BIRR, business-impact risk reduction (Eq. 7); oracle gap closed = (BIRR − 0.500)/(0.656 − 0.500). Confidence intervals resample evaluation incidents within profiles (1,000 draws); p from two-sided Wilcoxon signed-rank tests against KB-CIDS across the 18 profiles. “Profiles > equal” counts profiles in which a strategy outperforms equal allocation.

9

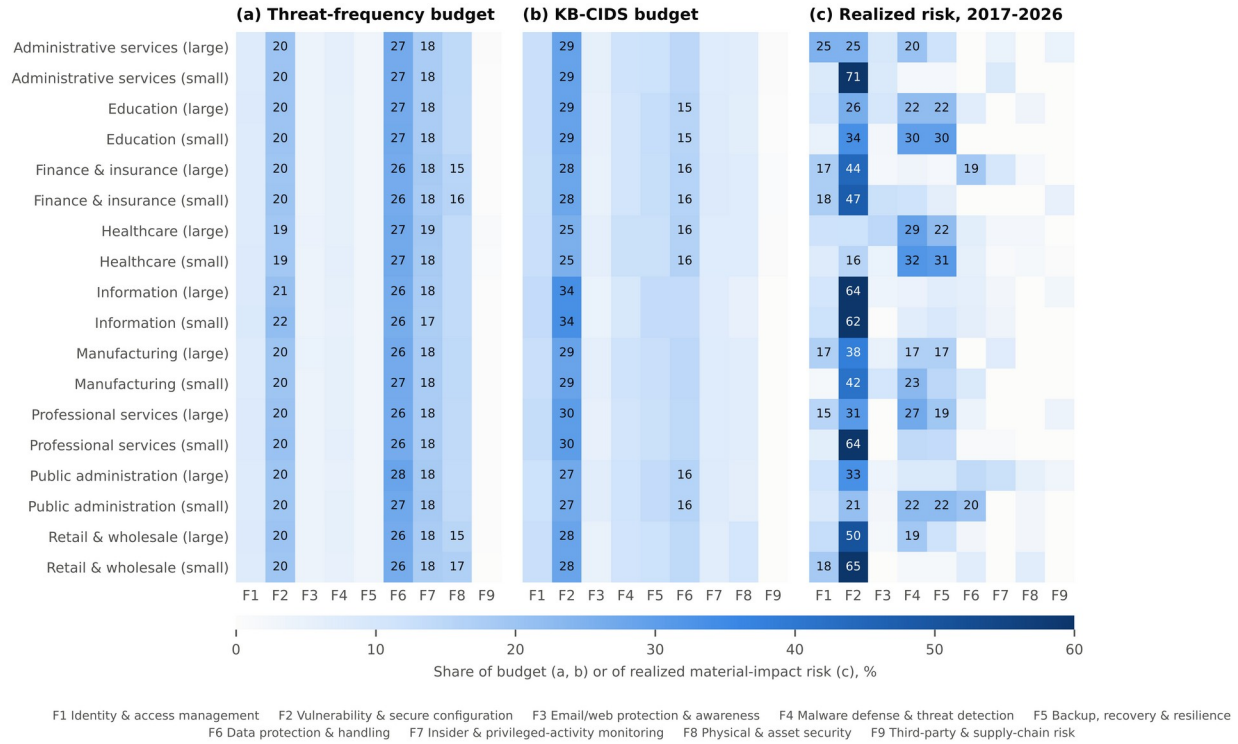


Fig. 1. Budget allocation versus realized business-impact risk for 18 sector–size profiles. (a) Threat-frequency allocation and (b) KB-CIDS allocation, both estimated from incidents up to 2016 at the reference budget; (c) realized share of material-impact risk addressed by each control family in 2017–2026. Values are percentages, and cells of at least 15% are labeled. F1–F9 denote the control families of Section 2.2. Generated programmatically from the study data.

The ablations clarify which components matter. Removing recency weighting reduced BIRR to 0.567 ($p < 0.001$), whereas removing context weighting reduced it only to 0.585 ($p = 0.074$), which indicates that sector–size cells are too sparse for strong context effects and that adaptation to drift carries most of the adaptive value. Removing AI imputation raised BIRR to 0.599 ($p < 0.001$; higher in 15 of 18 profiles), although imputation had been preferred on the inner validation split (0.560 vs 0.541). Impact magnitudes are therefore unlikely to be missing at random: large breaches are reported with record counts more often than small ones, so a model trained on determined outcomes over-weights incidents of unknown magnitude. We report this negative result explicitly and treat imputation as a switchable component whose use should be decided within the governance loop rather than assumed.

10

Fig. 2a shows that KB-CIDS dominated the baselines at every budget level from 0.1 to 10 times the reference, with the largest relative advantage when budgets are tight (BIRR 0.190 vs 0.091 for an equal split at one tenth of the reference), which is the typical situation of smaller organizations. Fig. 2b confirms that the gains are consistent across profiles rather than driven by a few sectors. The conclusions were robust: across six alternative specifications, KB-CIDS outperformed equal and threat-frequency allocation ($p \leq 0.008$ against threat frequency) and closed 34–67% of the oracle gap, and across nine (α, β) combinations it closed 43–62% while threat-frequency allocation remained below the equal split in every case (Tables S5–S6).

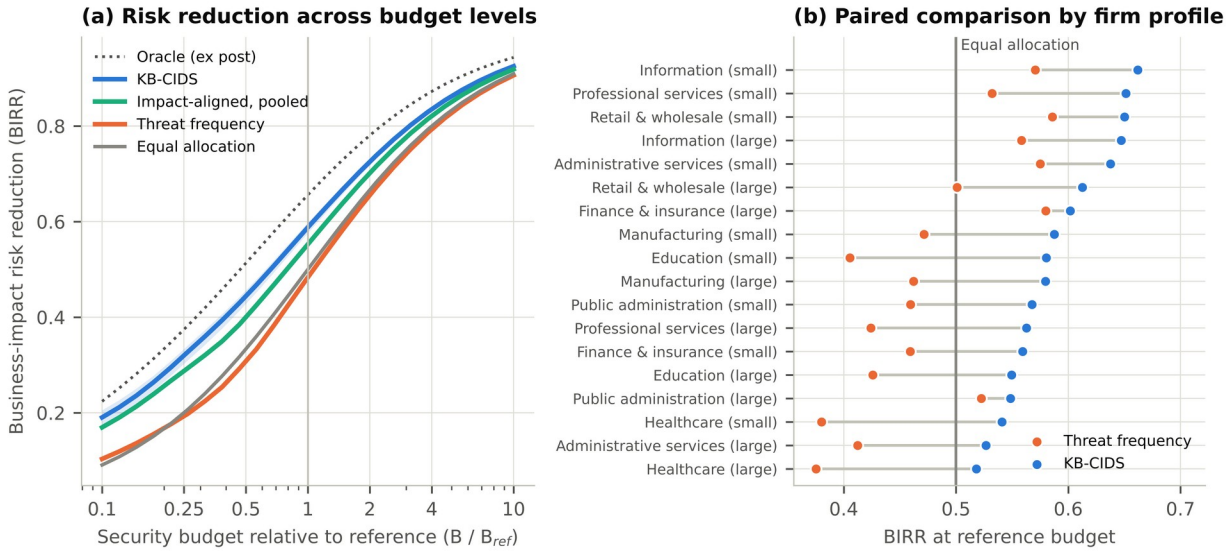


Fig. 2. Out-of-time business-impact risk reduction (BIRR). (a) Mean BIRR across the 18 profiles as a function of the security budget relative to the reference budget; the shaded band is the 95% bootstrap interval for KB-CIDS. (b) BIRR of threat-frequency allocation and KB-CIDS for each profile at the reference budget; the vertical line marks equal allocation (BIRR = 0.5). Generated programmatically from the study data.

4.3. Explainability and managerial implications

Because every allocation is generated by explicit rules, it can be audited. For small healthcare organizations, for instance, the backup-and-resilience budget is justified mainly by denial-of-service (40.5% of the family's risk) and ransomware incidents (34.5%), and the data-protection budget by publishing errors (26.3%), theft (24.7%) and misdelivery (20.8%) (Table S8). Three

11

implications follow for business leaders. First, budget allocation should be driven by business-impact-weighted exposure rather than by threat-frequency dashboards, which in our data performed worse than undifferentiated spending. Second, priorities should be re-estimated regularly as the threat mix shifts, in line with ex-post validation loops for security investment [19]. Third, imputed or assumed impacts should be treated as explicit assumptions and tested against new outcome data. Because material-impact incidents are those associated with market and operating losses [3–5], aligning investment with them is a direct lever for protecting business performance [7,8].

5. Limitations

VCDB reflects publicly reported incidents rather than a random sample; healthcare organizations and U.S. victims are over-represented, and impact magnitudes are frequently missing, as the imputation result illustrates. BIRR is a model-based proxy for protected business performance: it assumes the Gordon–Loeb response function, equal unit costs across control families and full mitigation scope of each family over the incidents mapped to it, and it measures neither realized financial losses nor causal effects. The rule base is expert-defined; ambiguous patterns such as hacking of unknown variety are split between identity management and vulnerability management (R8), and the mapping requires validation by practitioners. Sector–size cells are small, which limits context effects; hierarchical shrinkage or transfer learning could strengthen them. Finally, out-of-time calibration degraded under prevalence drift, so deployed models should be recalibrated as new outcome data arrive.

6. Conclusion

KB-CIDS shows that a compact knowledge base, a calibrated materiality model and a Gordon–Loeb allocation layer can turn public incident data into auditable cybersecurity investment decisions. On out-of-time data, aligning budgets with business-impact risk removed more risk than equal or threat-frequency allocation in every sector–size profile examined, knowledge features improved the prediction of material impact, and recency weighting mattered more than context

weighting, whereas imputing unknown impacts did not help. Future work will validate the rule base with practitioners, incorporate control costs and loss magnitudes, and test the approach on organization-level telemetry.

Data availability

The VERIS Community Database is publicly available at https://github.com/vz-risk/VCDB under a CC BY-SA 4.0 license; this study uses the joined release at commit f6f98c00f66ab35f5b49977a5852ce94a5bb31d1 [35]. The code, derived tables and figures are available at https://github.com/rahulchandranandagiri/cybersecurity-investment-business-performance, and running run_experiment.py regenerates every reported number. Supplementary tables S1–S10 accompany this article.

CRediT authorship contribution statement

Rahul Chandra Nandagiri: Conceptualization, Methodology, Software, Validation, Formal analysis, Investigation, Data curation, Visualization, Writing – original draft, Writing – review & editing.

Declaration of competing interest

The author declares that there are no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Funding

This research did not receive any specific grant from funding agencies in the public, commercial, or not-for-profit sectors.

Declaration of generative AI and AI-assisted technologies in the manuscript preparation process

During the preparation of this work the author used Claude (Anthropic) to assist with code development, drafting and language editing of the manuscript, and checking of references. After

13

using this tool, the author reviewed and edited the content as needed and takes full responsibility for the content of the published article. All figures are data visualizations or schematics produced programmatically by the analysis code from the study data; no generative image tools were used.

References

[1] G. Vial, Understanding digital transformation: A review and a research agenda, J. Strateg. Inf. Syst. 28 (2019) 118–144. https://doi.org/10.1016/j.jsis.2019.01.003.

[2] P.C. Verhoef, T. Broekhuizen, Y. Bart, A. Bhattacharya, J.Q. Dong, N. Fabian, M. Haenlein, Digital transformation: A multidisciplinary reflection and research agenda, J. Bus. Res. 122 (2021) 889–901. https://doi.org/10.1016/j.jbusres.2019.09.022.

[3] S. Kamiya, J.-K. Kang, J. Kim, A. Milidonis, R.M. Stulz, Risk management, firm reputation, and the impact of successful cyberattacks on target firms, J. Financ. Econ. 139 (2021) 719–749. https://doi.org/10.1016/j.jfineco.2019.05.019.

[4] D. Bianchi, O.K. Tosun, Cyber attacks and stock market activity, Int. Rev. Financ. Anal. 76 (2021) 101795. https://doi.org/10.1016/j.irfa.2021.101795.

[5] G.A.P. Rodrigues, A.L.M. Serrano, G.F. Vergara, R.O. Albuquerque, G.D.A. Nze, Impact, compliance, and countermeasures in relation to data breaches in publicly traded U.S. companies, Future Internet 16 (2024) 201. https://doi.org/10.3390/fi16060201.

[6] M. Eling, J. Wirfs, What are the actual costs of cyber risk events?, Eur. J. Oper. Res. 272 (2019) 1109–1119. https://doi.org/10.1016/j.ejor.2018.07.021.

[7] M. Podrecca, G. Culot, G. Nassimbeni, M. Sartor, Information security and value creation: The performance implications of ISO/IEC 27001, Comput. Ind. 142 (2022) 103744. https://doi.org/10.1016/j.compind.2022.103744.

[8] S. Hasan, M. Ali, S. Kurnia, T. Ramayah, Evaluating the cyber security readiness of organizations and its influence on performance, J. Inf. Secur. Appl. 58 (2021) 102726. https://doi.org/10.1016/j.jisa.2020.102726.

14

[9] K.C. Demek, S.E. Kaplan, Cybersecurity breaches and investors' interest in the firm as an investment, Int. J. Account. Inf. Syst. 49 (2023) 100616. https://doi.org/10.1016/j.accinf.2023.100616.

[10] L.A. Gordon, M.P. Loeb, The economics of information security investment, ACM Trans. Inf. Syst. Secur. 5 (2002) 438–457. https://doi.org/10.1145/581271.581274.

[11] C.D. Huang, R.S. Behara, Economics of information security investment in the case of concurrent heterogeneous attacks with budget constraints, Int. J. Prod. Econ. 141 (2013) 255–268. https://doi.org/10.1016/j.ijpe.2012.06.022.

[12] A. Nagurney, S. Shukla, Multifirm models of cybersecurity investment competition vs. cooperation and network vulnerability, Eur. J. Oper. Res. 260 (2017) 588–600. https://doi.org/10.1016/j.ejor.2016.12.034.

[13] J. Simon, A. Omar, Cybersecurity investments in the supply chain: Coordination and a strategic attacker, Eur. J. Oper. Res. 282 (2020) 161–171. https://doi.org/10.1016/j.ejor.2019.09.017.

[14] J.A. Paul, X. Wang, Socially optimal IT investment for cybersecurity, Decis. Support Syst. 122 (2019) 113069. https://doi.org/10.1016/j.dss.2019.05.009.

[15] M. Chronopoulos, E. Panaousis, J. Grossklags, An options approach to cybersecurity investment, IEEE Access 6 (2018) 12175–12186. https://doi.org/10.1109/ACCESS.2017.2773366.

[16] M. Brho, A. Jazairy, A.V. Glassburner, The finance of cybersecurity: Quantitative modeling of investment decisions and net present value, Int. J. Prod. Econ. 279 (2025) 109448. https://doi.org/10.1016/j.ijpe.2024.109448.

[17] A. Fielder, E. Panaousis, P. Malacaria, C. Hankin, F. Smeraldi, Decision support approaches for cyber security investment, Decis. Support Syst. 86 (2016) 13–23. https://doi.org/10.1016/j.dss.2016.02.012.

[18] I. Fernandez De Arroyabe, C.F.A. Arranz, M.F. Arroyabe, J.C. Fernandez de Arroyabe, Cybersecurity capabilities and cyber-attacks as drivers of investment in cybersecurity systems: A UK survey for 2018 and 2019, Comput. Secur. 124 (2023) 102954. https://doi.org/10.1016/j.cose.2022.102954.

15

[19] D. Owoleso, A. Montes Cohen, B. Köelmel, Closing the validation gap in cybersecurity investment: The CISO Investment Validation Loop (CIVL)—A design science approach to linking financial forecasts and operational metrics, J. Cybersecur. Priv. 6 (2026) 171. https://doi.org/10.3390/jcp6050171.

[20] M. Xu, K.M. Schweitzer, R.M. Bateman, S. Xu, Modeling and predicting cyber hacking breaches, IEEE Trans. Inf. Forensics Secur. 13 (2018) 2856–2871. https://doi.org/10.1109/TIFS.2018.2834227.

[21] H. Hammouchi, N. Nejjari, G. Mezzour, M. Ghogho, H. Benbrahim, STRisk: A socio-technical approach to assess hacking breaches risk, IEEE Trans. Dependable Secure Comput. 20 (2023) 1074–1087. https://doi.org/10.1109/TDSC.2022.3149208.

[22] A.H. Seh, M. Zarour, M. Alenezi, A.K. Sarkar, A. Agrawal, R. Kumar, R.A. Khan, Healthcare data breaches: Insights and implications, Healthcare 8 (2020) 133. https://doi.org/10.3390/healthcare8020133.

[23] B. Yankson, M. Barati, R. Bondzie, R. Madani, The rise of hacking in integrated EHR systems: A trend analysis of U.S. healthcare data breaches, J. Cybersecur. Priv. 5 (2025) 70. https://doi.org/10.3390/jcp5030070.

[24] A.L. Buczak, E. Guven, A survey of data mining and machine learning methods for cyber security intrusion detection, IEEE Commun. Surv. Tutor. 18 (2016) 1153–1176. https://doi.org/10.1109/COMST.2015.2494502.

[25] Y. Xin, L. Kong, Z. Liu, Y. Chen, Y. Li, H. Zhu, M. Gao, H. Hou, C. Wang, Machine learning and deep learning methods for cybersecurity, IEEE Access 6 (2018) 35365–35381. https://doi.org/10.1109/ACCESS.2018.2836950.

[26] A. Barredo Arrieta, N. Díaz-Rodríguez, J. Del Ser, A. Bennetot, S. Tabik, A. Barbado, S. García, S. Gil-López, D. Molina, R. Benjamins, R. Chatila, F. Herrera, Explainable Artificial Intelligence (XAI): Concepts, taxonomies, opportunities and challenges toward responsible AI, Inf. Fusion 58 (2020) 82–115. https://doi.org/10.1016/j.inffus.2019.12.012.

16

[27] N. Capuano, G. Fenza, V. Loia, C. Stanzione, Explainable artificial intelligence in cybersecurity: A survey, IEEE Access 10 (2022) 93575–93600. https://doi.org/10.1109/ACCESS.2022.3204171.

[28] Y. Jia, Y. Qi, H. Shang, R. Jiang, A. Li, A practical approach to constructing a knowledge graph for cybersecurity, Engineering 4 (2018) 53–60. https://doi.org/10.1016/j.eng.2018.01.004.

[29] I. Sarhan, M. Spruit, Open-CyKG: An open cyber threat intelligence knowledge graph, Knowl.-Based Syst. 233 (2021) 107524. https://doi.org/10.1016/j.knosys.2021.107524.

[30] J. Zhao, M. Shao, H. Wang, X. Yu, B. Li, X. Liu, Cyber threat prediction using dynamic heterogeneous graph learning, Knowl.-Based Syst. 240 (2022) 108086. https://doi.org/10.1016/j.knosys.2021.108086.

[31] J.G. Moreno-Torres, T. Raeder, R. Alaiz-Rodríguez, N.V. Chawla, F. Herrera, A unifying view on dataset shift in classification, Pattern Recognit. 45 (2012) 521–530. https://doi.org/10.1016/j.patcog.2011.06.019.

[32] C. Beaman, A. Barkworth, T.D. Akande, S. Hakak, M.K. Khan, Ransomware: Recent advances, analysis, challenges and future research directions, Comput. Secur. 111 (2021) 102490. https://doi.org/10.1016/j.cose.2021.102490.

[33] Center for Internet Security, CIS Critical Security Controls Version 8, Center for Internet Security, East Greenbush, NY, 2021. https://www.cisecurity.org/controls/v8 (accessed 23 October 2026).

[34] National Institute of Standards and Technology, The NIST Cybersecurity Framework (CSF) 2.0, NIST Cybersecurity White Paper CSWP 29, Gaithersburg, MD, 2024. https://doi.org/10.6028/NIST.CSWP.29.

[35] [dataset] Verizon RISK Team, VERIS Community Database (VCDB), GitHub repository, commit f6f98c00f66ab35f5b49977a5852ce94a5bb31d1, 2026. https://github.com/vz-risk/VCDB (accessed 23 October 2026).

[36] F. Pedregosa, G. Varoquaux, A. Gramfort, V. Michel, B. Thirion, O. Grisel, M. Blondel, P. Prettenhofer, R. Weiss, V. Dubourg, J. Vanderplas, A. Passos, D. Cournapeau, M. Brucher, M. Perrot, É. Duchesnay, Scikit-learn: Machine learning in Python, J. Mach. Learn. Res. 12 (2011) 2825–2830.